

Pentesting scan v1

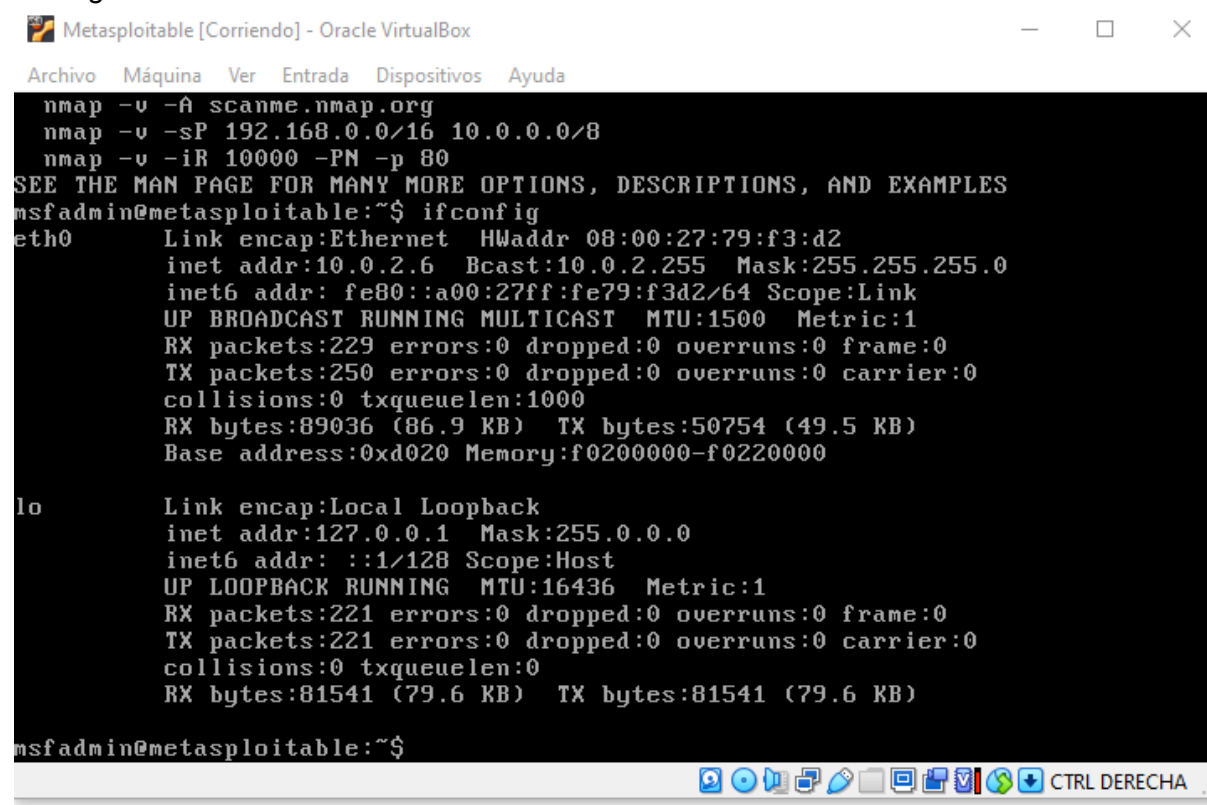
Después de instalar la máquina y dedicarle un buen tiempo de investigación para cambiarle la plantilla de teclado a esa “cosa”. He empezado con la práctica.

Objetivo y alcance: Hacer varios escaneos específicos sobre la información del sistema en uso y conocer posibles vulnerabilidades.

Herramientas y técnicas usadas:

- Máquina metasploitable
- Virtual Box
- Uso de la herramienta nmap y sus derivados parámetros.

Ifconfig



```
msfadmin@metasploitable:~$ nmap -v -A scanme.nmap.org
msfadmin@metasploitable:~$ nmap -v -sP 192.168.0.0/16 10.0.0.0/8
msfadmin@metasploitable:~$ nmap -v -iR 10000 -PN -p 80
SEE THE MAN PAGE FOR MANY MORE OPTIONS, DESCRIPTIONS, AND EXAMPLES
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:79:f3:d2
          inet addr:10.0.2.6  Bcast:10.0.2.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe79:f3d2/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:229 errors:0 dropped:0 overruns:0 frame:0
          TX packets:250 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:89036 (86.9 KB)  TX bytes:50754 (49.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128  Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:221 errors:0 dropped:0 overruns:0 frame:0
          TX packets:221 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:81541 (79.6 KB)  TX bytes:81541 (79.6 KB)

msfadmin@metasploitable:~$
```

He usado de primer comando el escaneo básico:

“nmap (ip) | less” (less ya que no puedo ver todo lo que me imprime)

```
Metasploitable [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

Starting Nmap 4.53 ( http://insecure.org ) at 2025-11-14 15:12 EST
Interesting ports on 10.0.2.6:
Not shown: 1692 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgres
5900/tcp  open  vnc
:
```

Ahora pruebo con: “nmap -sV (ip)”, para detectar versiones y servicios.

```
Metasploitable [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

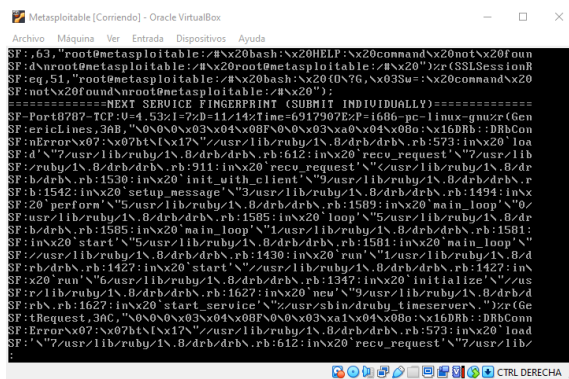
Starting Nmap 4.53 ( http://insecure.org ) at 2025-11-14 15:18 EST
Interesting ports on 10.0.2.6:
Not shown: 1692 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (rpc #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  rlogin
514/tcp   open  tcpwrapped
1524/tcp  open  ingreslock?
2049/tcp  open  nfs          2-4 (rpc #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB
5900/tcp  open  vnc           VNC (protocol 3.3)
:
```

Lanzo ahora el siguiente comando para comprobar el SO: “nmap -O (ip)”

```
1 1 01
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.17 - 2.6.18 (x86)
Uptime: 0.033 days (since Fri Nov 14 14:36:06 2025)
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at http://insecure.org/nmap/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.485 seconds
(END)
```

Para un escaneo completo de puertos y servicios usamos “-A”:



```
msfadmin@metasploitable:~$ nmap --script ftp-anon, ftp-brute -21 10.0.2.6
```

Resultados de vulnerabilidades:

Servicio	FTP	SSH	SMTP	HTTP	Samba	MySQL	PostgreSQL
Vulnerabilidad	vsftpd 2.3.4	OpenSSH	Postfix smtpd	Apache 2.2.8	Samba smbd 3.X	MySQL 5.0.51a	PostgreSQL DB
Impacto	Contiene una puerta trasera que permite el acceso remoto si se usa un nombre de usuario con ":".	Versión antigua susceptible a ataques de fuerza bruta y posibles exploits de desbordamiento de búfer.	Puede ser explotado para enumerar usuarios locales mediante técnicas de fuzzing o fuerza bruta.	Ataques mediante Directory Traversal, y XSS entre otros.	Vulnerable al exploit "username man script" que permite ejecución remota de comandos como root.	Vulnerable a credenciales por defecto, inyecciones SQL y acceso no autenticado si no se configura bien.	Permite acceso remoto si se usan credenciales por defecto o inseguras.

Mitigación: Actualizar las versiones de los servicios en caso de ser posible y deshabilitar servicios en desuso.